Индикаторы компрометации Rare Werewolf: красные флаги на каждом шагу

Автор: Григорий Емельянов

специалист по выявлению и оценке угроз КИ и КА

15.09.2026

© Емельянов Григорий Андреевич github.com/emelyagr Все права защищены

Введение

Rare Werewolf (она же Rezet, Librarian Ghouls, Librarian Likho) — предположительно проукраинская хакерская группировка, действующая как минимум с 2019 года. Основная цель — шпионаж и финансовая выгода с фокусом на промышленные предприятия и образовательные учреждения в России, Беларуси и Казахстане. Среди целей атак — сбор логинов, паролей, документов, переписок в мессенджерах и внедрение криптомайнера XMRig.

Атаки проводятся с использованием легальных программ и PowerShell-скриптов, что позволяет долго оставаться незамеченными и усложняет расследование. Отличительная особенность в деятельности группировки заключается в том, чтобы максимально использовать легитимное программное обеспечение и встроенные функции операционной системы для достижения злоумышленных целей («Living off the Land» (LOTL)). Это позволяет эффективно маскироваться на заражённой системе, ведь активность программ по типу curl.exe, AnyDesk.exe или установщика WinRAR редко вызывает подозрения у рядовых пользователей и даже у некоторых систем защиты.

Специалистами регулярно выявляются и анализируются фишинговые письма, поступающие в организации промышленного сектора, а также сетевая инфраструктура и особенности, позволяющие атрибутировать данную хакерскую группировку, определять её возможности, цели, а также своевременно прогнозировать компьютерные атаки на основе выявления регистрируемых доменных имён, имитирующих названия организаций-жертв.

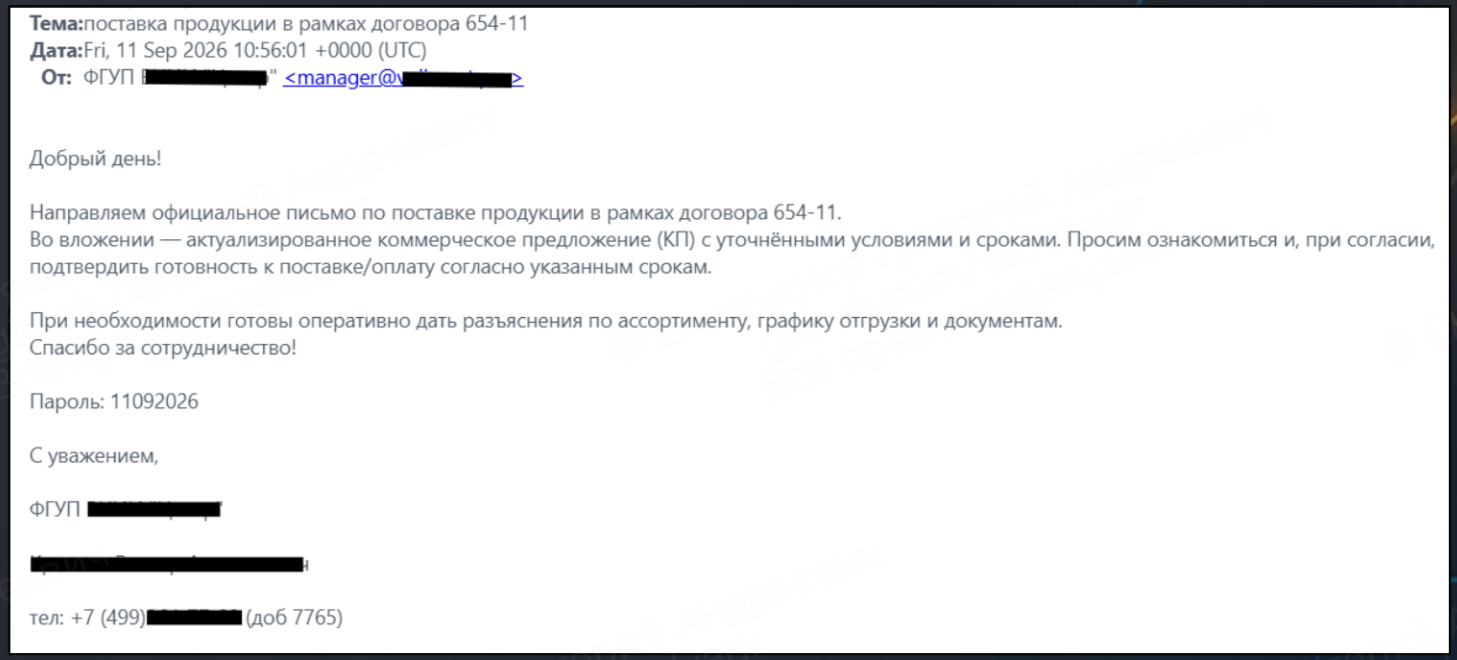
Целеполагание, возможности и статистика

Группировка регулярно рассылает письма от имени двух-трёх реальных организаций. Для этого она постоянно регистрирует новые доменные имена, визуально и фонетически похожие на легитимные. Письма выглядят не как шаблонный спам, а как начало или продолжение реальной деловой переписки — с корректными подписями, телефонными номерами, упоминанием контрагентов, ссылками на документы.

Ключевая особенность кампаний — глубокая осведомлённость о жертвах. Группировка демонстрирует знание партнёров, бизнес-процессов, сотрудников, сетевой инфраструктуры и контактных данных промышленных организаций. Это позволяет ей подбирать контекст, который почти не вызывает подозрений: тендеры, закупки, логистика, согласования счетов, техническая документация, кадровые вопросы. Однако чаще всего группировка использует легенду коммерческих предложений, тем самым нацеливаясь на сотрудников отдела продаж и коммерции.

Такой уровень рекогносцировки указывает на длительную подготовку, комбинацию открытых источников, утечек и, ранее скомпрометированных информационных систем организаций. Фишинг перестал быть «письмом с ошибками» — он превратился в имитацию нормальной рабочей коммуникации.

Один из примеров таких писем представлен на рисунке 1, Rare Werewolf использует легенду с «официальным письмом» по поставке продукции в рамках договора, прикрепляя вредоносный архив формата «.zip», содержащий загрузчик формата «.bat».



Тема:поставка продукции в рамках договора 654-11
Дата: Fri, 11 Sep 2026 10:56:01 +0000 (UTC)
От: ФГУП [redacted]" <manager@[redacted]>

Добрый день!

Направляем официальное письмо по поставке продукции в рамках договора 654-11.
Во вложении — актуализированное коммерческое предложение (КП) с уточнёнными условиями и сроками. Просим ознакомиться и, при согласии, подтвердить готовность к поставке/оплату согласно указанным срокам.

При необходимости готовы оперативно дать разъяснения по ассортименту, графику отгрузки и документам.
Спасибо за сотрудничество!

Пароль: 11092026

С уважением,

ФГУП [redacted]

[redacted]

тел: +7 (499)[redacted] (доб 7765)

Рисунок 1 – Фишинговое письмо от Rare Werewolf

В другом письме (рис. 2) группировка имитирует коммерческое предложение: во вложении прикреплен архив с наименованием «Коммерческое предложение 762-91 для рассмотрения и согласования.rar», содержащий исполняемый файл с наименованием «Коммерческое предложение 762-91 для рассмотрения и согласования.scr». После запуска пользователем указанного файла осуществляется демонстрация документа-приманки и внедрение на целевую систему вредоносного программного обеспечения типов «дроппер», «стилер» и «загрузчик», а также программного обеспечения для получения удаленного доступа «AnyDesk» и «RustDesk».



From: [redacted] [mailto:buh@[redacted]]
Sent: Tuesday, June 9, 2026 9:37 AM
Subject: Коммерческое предложение 762-91 для рассмотрения и согласования

МИНИСТЕРСТВО
ПРОМЫШЛЕННОСТИ
И ТОРГОВЛИ
РОССИЙСКОЙ ФЕДЕРАЦИИ
(МИНПРОМТОРГ РОССИИ)

Пресненская наб., д. 10, стр. 2, Москва, 125039
Тел. (495) 539-21-66
Факс (495) 547-87-83
http://www.minpromtorg.gov.ru

Уважаемые коллеги!

В соответствии с достигнутыми ранее договорённостями направляем на рассмотрение коммерческое предложение 762-91.
В документе представлены актуальные условия поставки, стоимость, сроки выполнения и основные технические параметры.

Просим ознакомиться с направленным предложением и, при наличии замечаний либо предложений, сообщить их в ответном письме.
После получения Вашего подтверждения будет подготовлена окончательная редакция документа для последующего подписания.

Приложение:

- Коммерческое предложение 5462-91 (PDF, 2 стр.)

Будем признательны за обратную связь до 22.05.2026 для соблюдения установленного графика согласования.

пароль: KP0906

С уважением,
[redacted]
Главный специалист [redacted]
+7 (495) [redacted] (доб. 7765)

Рисунок 2 – Фишинговое письмо от Rare Werewolf

В качестве почтовых адресов отправителей используется недавно зарегистрированные домены, имитирующие ранее скомпрометированную организацию промышленного сектора (дважды: в 2024 и 2026 годах). Похожих доменных имён специалистами выявлено более 20. На данный момент это одна из отличительных особенностей данной группировки. При этом можно отметить и наименование других организаций, фишинговых доменных имён которых выявлено меньше 10.

В качестве доменных зон замечены: «.space»; «.cc»; «.cloud»; «.email»; «.site» «.online»; «.click»; «.ru»; «.pro». В названии доменов используется подмена символов и добавления по типу: «fguib» / «fgub»; «-digital»; «-out»; «official»; «center».

Исходя из статистики сетевой инфраструктуры (рис. 3) наиболее активных хакерских группировок (ориентированных на российский сектор), собранной специалистами на основе расследования инцидентов, анализа открытых источников и данных, полученных от ФСТЭК России, можно сделать вывод, что вероятно, возможности Rare Werewolf крупнее, чем у большинства аналогичных проукраинских акторов. Речь идёт о большом пуле доменов, IP-адресов, почтовых серверов, редиректов. Домены быстро ротируются, часть из них живёт недели, часть — месяцы. Это позволяет сохранять высокую интенсивность рассылок и одновременно усложнять блокировку.

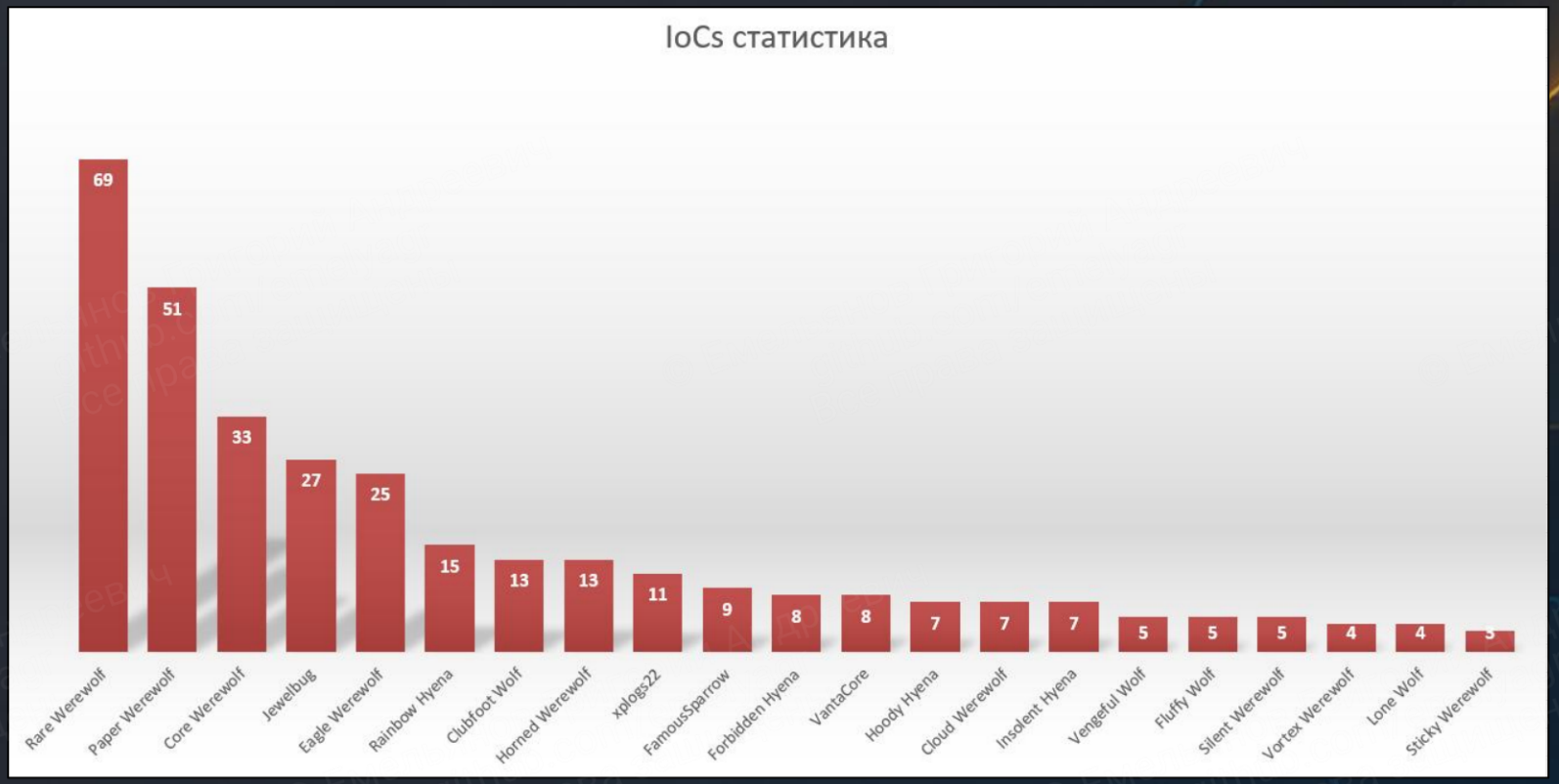


Рисунок 3 – Статистика сетевой инфраструктуры группировок

За последние 2-3 месяца именно эта группировка выглядит наиболее активной в своём сегменте. Возможны два объяснения: либо она действительно нарастила возможности, либо стала легче выявляться из-за масштаба и менее аккуратной инфраструктурной гигиены. Не исключено и сочетание обоих факторов.

На фоне роста активности этой группы заметно «затихли» Rainbow Hyena (Head Mare) и Phantom Core. Это может быть временной паузой, сменой приоритетов или перераспределением ресурсов. Нельзя

исключать, что часть функций, инфраструктуры и экспертизы перешла к более активному актору, а отдельные команды могли объединиться.

Прямых доказательств слияния пока нет. Для подтверждения нужны пересечения по IoCs, доменной инфраструктуре, тактикам, временным паттернам и почтовым сервисам, чего пока замечено не было. Однако сам паттерн — резкий рост одного игрока на фоне затишья двух других — как минимум заслуживает внимания.

Анализ ВПО

В фишинговом письме проведенный анализ ВПО подтвердил присутствие сигнатур (хэш: b937b7d7ef67f6931b1497a5aefe95e0b34a4a510aa849863c7f8f61908149e9), обозначенных как загрузчики ВПО (Trojan.Win32.Generic.a; Trojan.Win32.RareWolf.c). Наименование сигнатуры также подтверждает атрибуцию группировки (рис. 4).

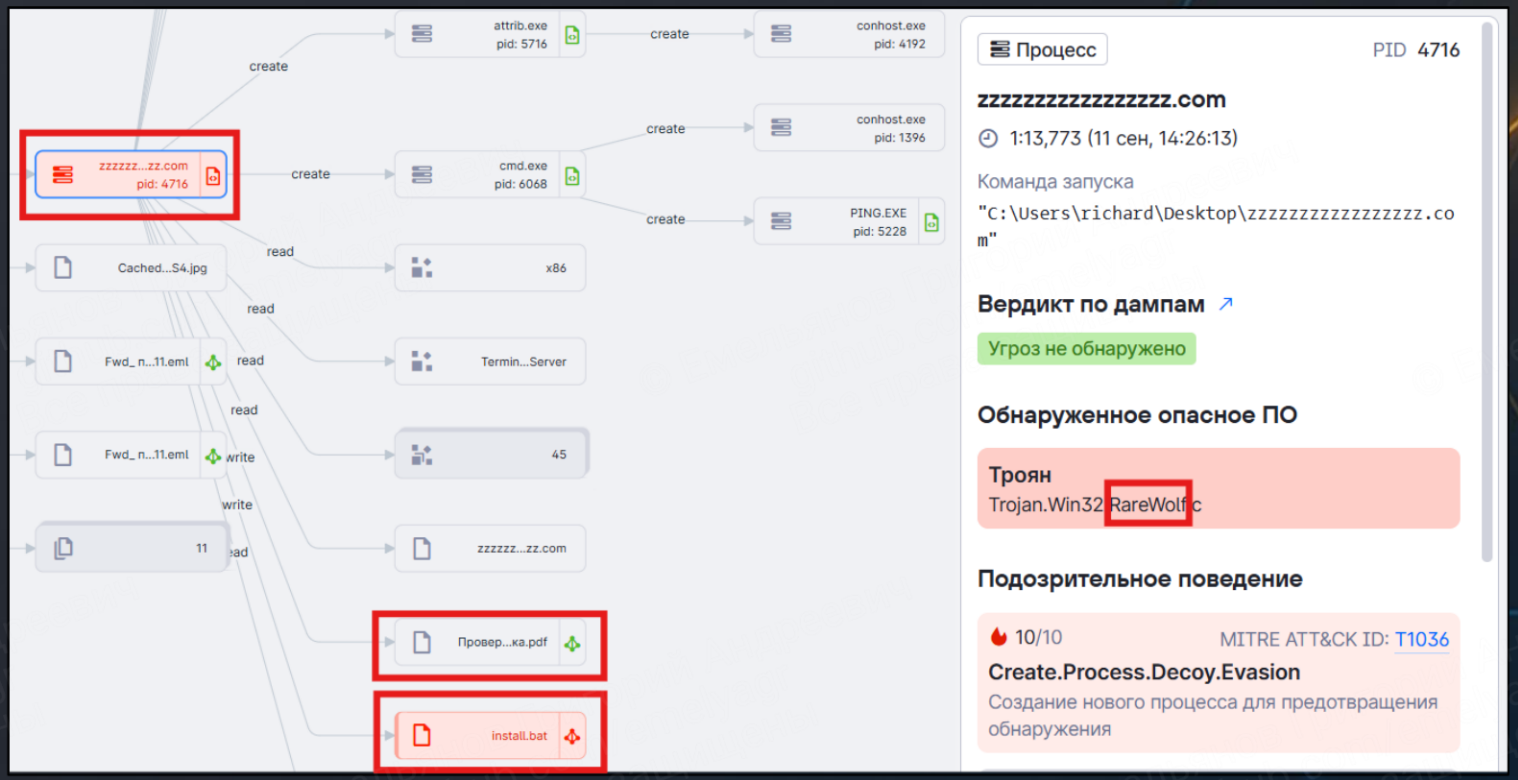


Рисунок 4 – Подтверждение атрибуции группировки на основе сигнатуры

После запуска данного вредоносного программного обеспечения открывается файл приманка «Проверка чека.pdf» и загрузчик ВПО «install.bat».

Скрипт пытается загрузить удаленный архивный файл с помощью curl.exe (в обход проверки SSL-сертификата и принудительного разрешения домена) или Invoke-WebRequest. Затем он находит стандартные установки WinRAR или 7-Zip, чтобы извлечь содержимое архива в указанный каталог назначения, используя жестко заданный пароль.

После извлечения скрипт проверяет наличие исполняемого файла с именем Trays.exe. и запускает его. Затем он автоматически запускает установщик AnyDesk, ожидает завершения установки и настраивает автоматический удаленный доступ, передавая заранее заданный пароль в двоичный файл AnyDesk.

Скрипт архивирует данные конфигурации из %ProgramData%\AnyDesk в зашифрованный архив RAR или ZIP. Затем он запускает blat.exe – инструмент командной строки для отправки электронной почты, чтобы передать архив и идентификационные данные хоста (имя компьютера и имя пользователя) на внешний SMTP-сервер.

С помощью PowerShell регистрируется запланированная задача под названием «Microsoft apdate», которая запускается Trays.exe с повышенными привилегиями при входе пользователя в систему. Наконец, скрипт удаляет временные и исполняемые файлы из промежуточной директории и выполняет фоновую команду для удаления себя с диска.

Таким образом, помимо анализа почтовых адресов отправителей фишинговых писем и сетевой инфраструктуры Rare Werewolf, можно выделить особенности используемых техник и ПО, которые преобладают у данной группировки, а именно:

- использование легитимного ПО сторонних разработчиков;
- 4t Tray Minimizer — инструмент, сворачивающей приложения в трей;
- Defender Control — программа для отключения антивируса;
- Blat — утилита для отправки данных через SMTP;

- AnyDesk — популярный инструмент удалённого доступа.

Скрипты запускают PowerShell-команды, которые активируют систему ночью (в 01:00) и дают хакерам четырёхчасовой доступ, после чего устройство выключается по расписанию в 05:00.

Также группировка применяла скрипт, который автоматически нажимал кнопки в системных окнах Windows, не оставляя пользователю возможности отказаться от запуска опасного ПО. Злоумышленники собирают информацию о доступных ядрах CPU и графических процессорах, чтобы оптимально настроить майнер, и отправляют её на свои сервера.

Заключение и прогнозы

У промышленных организаций сложные цепочки поставок, множество подрядчиков, длительные циклы согласования, высокая ценность учётных данных и зачастую недостаточно сегментированные сети. Фишинг в такой среде — это не только кража пароля. Это потенциальный первый шаг к компрометации партнёров, развитию атаки на цепочку поставок, краже коммерческой тайны, финансовому мошенничеству и попыткам добраться до технологических систем. Даже если конкретная кампания нацелена только на сбор учётных данных, последствия могут быть отложенными и куда более серьёзными, чем просто потеря одного почтового ящика.

Вредоносные кампании, скорее всего, продолжатся и будут адаптироваться под сезонность: отчётные периоды, закупки, тендеры, конец квартала, отпуска, кадровые изменения. Атакующие будут использовать реальные события, имена, номера телефонов и деловую лексику. Домены будут жить недолго, но появляться быстро. Возможен переход от простого сбора credentials к более сложным

сценариям: BEC-атакам, компрометации OAuth-приложений, атакам на подрядчиков, использованию легитимных сервисов для рассылок и дальнейшего закрепления в инфраструктуре.

Мы, вероятно, видим не просто очередной всплеск фишинга, а перераспределение ресурсов в проукраинском хакерском сегменте. Группировка стала зрелее, агрессивнее и лучше подготовлена к атакам на промышленность. Затишье Head Mare и Phantom Core может быть временным, а возможное слияние команд — рабочей гипотезой, требующей проверки. Промышленным организациям стоит

исходить из того, что фишинг будет всё чаще выглядеть как обычная деловая переписка. Защищаться от него нужно не только техническими средствами, но и через процессы, обучение сотрудников и проверку цепочек поставок. Лучшая стратегия — снижать ценность фишинга: делать украденные учётные данные недостаточными для развития атаки, сегментировать сети, контролировать доступы и быть готовыми к инциденту до того, как он произойдёт.